RELATÓRIO TÉCNICO DE VULNERABILIDADES

CVEs recentes do PHP

Análise detalhada: julho a outubro de 2026

Inclui PHP2Shell (CVE-2026-109618 e CVE-2026-109619)

Data de referência: 21 de outubro de 2026
Escopo: PHP 8.2, 8.3, 8.4 e 8.5 (php-src) — 17 CVEs analisadas em detalhe
Fontes primárias: GitHub Security Advisories (php/php-src), php.net ChangeLog, PHP Foundation, Debian Security Tracker e CIRCL/NVD

Documento de estudo. As informações refletem os avisos oficiais publicados até a data de referência; consulte sempre as fontes originais antes de tomar decisões em ambiente de produção.

Sumário

1. Sumário executivo **3**

2. Conceitos para entender este relatório **5**

3. Lançamento crítico de 21/10/2026 — PHP2Shell **6**

3.1 CVE-2026-109618 — RCE via corrupção por falta de memória (OOM) . . . 6

3.2 CVE-2026-109619 — RCE via estado global obsoleto . . . 7

4. Lançamento de segurança de 24/09/2026 **10**

4.1 CVE-2026-91765 — SOAP: recursão ilimitada em cleanup_xml_node() . . . 10

4.2 CVE-2026-91768 — PHP-FPM: bypass de ACL IPv6 . . . 10

4.3 CVE-2026-91767 — OpenSSL: heap overflow em wildcard de certificado . . . 11

4.4 CVE-2025-14181 — SOAP: integer overflow no parsing HTTP . . . 11

4.5 CVE-2026-17545 — Windows: nomes de dispositivo reservados . . . 12

4.6 CVE-2026-91766 — Vazamento de credenciais em redirects HTTP . . . 12

4.7 CVE-2026-92842 — Leitura fora dos limites em filtros convert.* . . . 13

4.8 CVE-2026-93682 — Leitura de 1 byte em redirect com Location vazio . . . 13

4.9 CVE-2026-91769 — TLS: fallback indevido para o Common Name . . . 14

4.10 CVE-2026-6103 — Phar: integer overflow e injeção de entradas TAR . . . 14

4.11 CVE-2025-1218 — mysqlnd: leituras além do pacote . . . 15

5. Lançamento de segurança de 30/07/2026 **16**

5.1 CVE-2026-17543 — Injeção de SQL em ext-pgsql . . . 16

5.2 CVE-2026-17544 — Escrita fora dos limites em bccomp() . . . 16

5.3 Outras CVEs de 30/07/2026 . . . 17

6. Recomendações práticas **18**

Apêndice A — CVEs do PHP no 1º semestre de 2026 (resumo) **19**

Fontes de pesquisa **19**

1. Sumário executivo

Este relatório analisa as vulnerabilidades (CVEs) corrigidas pelo projeto PHP nas quatro últimas rodadas de lançamentos de segurança — 30/07, 27/08 (sem CVEs), 24/09 e 21/10/2026 — e explica, para cada uma, **o que ela identifica** (a falha de código na raiz), **como é explorada**, **qual o impacto** e **como corrigir ou mitigar**. No apêndice há uma tabela com as CVEs do primeiro semestre de 2026 para referência.

O destaque absoluto é o par **CVE-2026-109618** e **CVE-2026-109619**, apelidado na imprensa de **PHP2Shell**: duas falhas críticas (CVSS v4.0 9,2) no núcleo do PHP que permitem **execução remota de código sem autenticação**. Ambas foram corrigidas hoje (21/10/2026) nas versões **8.5.12, 8.4.27, 8.3.36 e 8.2.35**. Segundo a PHP Foundation, o problema remonta a decisões de projeto muito antigas — a Laravel Forge afirma que as falhas afetam versões desde 2004 — e o PHP 8.1 ou anterior não receberá correção oficial.

Principais conclusões

- **Atualizar é a única correção completa** para o PHP2Shell. As mitigações por configuração reduzem caminhos de ataque, mas não fecham o problema.
- O ambiente **Apache + mod_php** é o mais exposto: a exploração ocorre antes de qualquer código da aplicação ser executado.
- A rodada de 24/09 trouxe 11 CVEs de gravidade baixa a alta, concentradas em **streams HTTP/TLS** (vazamento de credenciais em redirect, verificação de hostname, overflow em wildcard), **SOAP**, **Phar**, **PHP-FPM** e **Windows**.
- Em 30/07 destacam-se uma **injeção de SQL** nas funções `pg_*()` da extensão PostgreSQL e uma **escrita fora dos limites** em `bccomp()`.
- Segundo a PHP Foundation, a equipe de segurança publicou 15 CVEs desde 1º de julho e triou mais de 100 relatos inválidos ou duplicados — reflexo do aumento de pesquisa assistida por IA.

Visão geral das CVEs analisadas

CVE	Componente	Tipo de falha	Gravidade	Lançamento
CVE-2026-109618	Núcleo (Zend MM / OOM)	RCE via corrupção por falta de memória	Crítica 9.2 (v4)	21/10/2026
CVE-2026-109619	Núcleo (estado global)	RCE via estado global obsoleto (use-after-free)	Crítica 9.2 (v4)	21/10/2026
CVE-2026-91765	ext-soap	Recursão ilimitada → DoS	Alta 7.5	24/09/2026
CVE-2026-91768	PHP-FPM	Bypass de ACL IPv6	Moderada 6.5	24/09/2026
CVE-2026-91767	ext-openssl	Heap overflow (leitura) em wildcard de certificado	Moderada 6.5	24/09/2026
CVE-2025-14181	ext-soap	Integer overflow → heap overflow	Moderada 6.5	24/09/2026
CVE-2026-17545	Windows (I/O)	Nomes de dispositivo reservados → DoS	Moderada 6.9 (v4)	24/09/2026
CVE-2026-91766	ext-standard (HTTP)	Vazamento de credenciais em redirect	Moderada 5.9	24/09/2026
CVE-2026-92842	ext-standard (filtros)	Leitura fora dos limites / vazamento de memória	Moderada 5.9	24/09/2026
CVE-2026-93682	ext-standard (HTTP)	Leitura de 1 byte fora dos limites	Moderada 5.3	24/09/2026
CVE-2026-91769	ext-openssl	Fallback indevido para CN na verificação TLS	Moderada 4.3	24/09/2026
CVE-2026-6103	ext-phar	Integer overflow → injeção de entradas TAR	Moderada 4.0	24/09/2026

CVE	Componente	Tipo de falha	Gravidade	Lançamento
CVE-2025-1218	ext-mysqlnd	Leituras além do pacote (protocolo MySQL)	Baixa 3.1	24/09/2026
CVE-2026-17543	ext-pgsql	Injeção de SQL (E'...' + barra invertida)	Alta	30/07/2026
CVE-2026-17544	ext-bcmath	Escrita fora dos limites em bccomp()	Alta	30/07/2026
CVE-2026-7260	ext-phar	Links simbólicos circulares → DoS	—	30/07/2026
CVE-2026-9672	ext-gd (libgd)	Atualização da libgd embutida	—	30/07/2026

CVSS v3.1 salvo indicação “(v4)”. “—” = gravidade não publicada no aviso consultado.

2. Conceitos para entender este relatório

Algumas noções técnicas aparecem em quase todas as CVEs. Vale tê-las claras antes de seguir:

Termo	Significado
CVE / GHSA	CVE é o identificador público e universal de uma vulnerabilidade. GHSA é o identificador do aviso no GitHub Security Advisories, onde o projeto php-src publica os detalhes técnicos.
CVSS	Pontuação de 0 a 10 que mede a gravidade. O vetor (ex.: AV:N/AC:H/PR:N) descreve vetor de ataque, complexidade, privilégios exigidos e impacto em confidencialidade, integridade e disponibilidade.
RCE	Remote Code Execution: o atacante executa código próprio no servidor remotamente.
Use-after-free (UAF)	O programa continua usando um ponteiro para uma área de memória que já foi liberada; se o atacante conseguir colocar dados próprios ali, pode desviar a execução.
OOM	Out Of Memory: falta de memória. No PHP, ocorre quando uma requisição ultrapassa o memory_limit.
longjmp()	Função C que “salta” para um ponto anterior do programa, abandonando o que estava sendo feito. O PHP usa esse mecanismo (bailout) para abortar requisições em erro fatal.
Heap / stack overflow	Escrita ou leitura além do fim de um buffer, na memória dinâmica (heap) ou na pilha (stack).
Integer overflow	Um cálculo numérico ultrapassa o tamanho do tipo e “dá a volta” (ex.: 2^32 vira 0), gerando tamanhos errados.
SAPI	A camada que conecta o PHP ao servidor: mod_php (Apache), PHP-FPM, CGI, FrankenPHP, LiteSpeed (LSAPI), CLI.
Worker	Processo que atende requisições. Em mod_php e FPM, o mesmo worker atende várias requisições em sequência — o que permite que “sujeira” de uma afete a próxima.

3. Lançamento crítico de 21/10/2026 — PHP2Shell

Em 21 de outubro de 2026 o projeto PHP publicou as versões **8.5.12, 8.4.27, 8.3.36 e 8.2.35** para corrigir duas falhas críticas relacionadas. A data original era 22/10, mas o lançamento foi antecipado em um dia porque os identificadores das CVEs vazaram em fóruns e redes sociais em 20/10, acompanhados de horário e nota CVSS incorretos (10,0, em vez de 9,2). Nenhum detalhe técnico vazou junto, segundo a PHP Foundation. O ChangeLog do php.net agrupa ambas as correções na mesma entrada do Core: “Avoid state corruption via bailout”.

Todas as instalações de PHP que atendem requisições web estão no escopo — PHP-FPM, Apache com mod_php, php-cgi, FrankenPHP e LiteSpeed — e o NCSC do Reino Unido recomendou tirar do ar sistemas que não possam ser corrigidos de imediato.

3.1 CVE-2026-109618 — RCE via corrupção por falta de memória (OOM)

CVE-2026-109618	CRÍTICA · CVSS v4.0 9.2
Título oficial	RCE via OOM corruption
Componente	php-src — núcleo (gerenciador de memória e tratamento de OOM)
Aviso (GHSA)	GHSA-w8hw-w9fx-j79w
Vetor CVSS	CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
Fraqueza (CWE)	CWE-416 (use-after-free), CWE-755, CWE-824 (ponteiro não inicializado), CWE-1325, CWE-1419
Versões afetadas	< 8.2.35, < 8.3.36, < 8.4.27, < 8.5.12 (e versões sem suporte, como 8.1 e anteriores)
Corrigido em	8.2.35, 8.3.36, 8.4.27, 8.5.12
Créditos	Relatores: lcfr-hax, sagitzadik-wiz (Wiz), tomash-areion, amyb-oai (OpenAI). Correção: arnaud-lb, iluuu1994, bukka, ndossche

O que esta CVE identifica

Quando uma requisição estoura o `memory_limit`, o PHP usa `longjmp()` para abandonar imediatamente o contexto atual e abortar a requisição. O problema é que, em alguns trechos do código, uma estrutura de memória da requisição já fica **acessível antes de estar totalmente inicializada**. Se *qualquer* alocação falhar nesse intervalo — mesmo uma alocação sem relação com a estrutura — o salto deixa a memória em estado inválido. Depois, o procedimento de encerramento (shutdown) da requisição lê ou toma decisões com base nesses dados corrompidos, e isso pode ser transformado em execução de código.

Em outras palavras: o defeito não está numa função específica, mas no **modelo de tratamento de erro do motor** — o “salto de emergência” não respeita trechos que não estão preparados para serem interrompidos.

Como o atacante força a falta de memória

O aviso oficial lista estratégias que fazem a requisição atingir OOM mesmo respeitando os limites aparentes do PHP, todas no processamento de formulários *multipart*:

- Uma requisição multipart sem tamanho declarado utilizável pode passar pela checagem inicial de `post_max_size` e continuar enviando corpo decodificado.
- Uma parte do multipart pode conter um número ilimitado de cabeçalhos; a representação interna deles consome muito mais memória do que ocupam na rede.
- Campos de arquivo vazios não contam para `max_file_uploads`, mas ainda criam os arrays de metadados; nomes de campos aninhados multiplicam esse trabalho.

- Além disso, qualquer entrada controlada pelo atacante que provoque alocações grandes na aplicação também serve como gatilho.

Ambientes e alcance

Apache mod_php: chama o shutdown da requisição incondicionalmente, mesmo quando a inicialização falhou. Como o parsing automático do corpo acontece na inicialização, o ataque ocorre **antes de qualquer código da aplicação**. A RCE completa foi validada via HTTP com limites padrão de entrada e memória e configurações prefork comuns.

PHP-FPM: encerra o processo filho se a inicialização falhar, o que bloqueia esse caminho específico; mas, após a inicialização, um OOM em contexto vulnerável continua possível. A PHP Foundation informa que RCE também foi confirmada no FPM por caminhos de código da aplicação.

FrankenPHP se comporta de forma análoga ao mod_php (provavelmente suscetível sem depender da aplicação); **LSAPI** se parece com o FPM.

Impacto

Execução remota de código sem autenticação, com os privilégios da conta do servidor web. A confiabilidade do exploit depende do build, das extensões, do frontend e do layout do alocador; mais workers e tráfego aumentam o número de tentativas necessárias, mas não eliminam a condição.

Correção aplicada

O patch **elimina o uso de longjmp() para OOM**. No lugar entra um “soft OOM” gracioso, disparado no próximo ponto seguro da máquina virtual, e um “hard OOM” imediato via `_exit()` caso o consumo atinja um segundo limite, mais alto. Assim o shutdown nunca vê estado inválido e o PHP continua limitando a memória.

Mitigações se não for possível atualizar já (parciais)

- Definir e impor administrativamente `memory_limit=-1` remove o limite previsível usado no exploit confirmado — **não** é mitigação completa (falhas de `mmap()` ainda acionam o caminho vulnerável). Reinicie todos os workers e garanta que nenhum pool/diretório reative um limite finito; use um limite de memória do servidor no lugar.
- Manter `post_max_size` conservador e impor o tamanho decodificado no frontend; reduzir `max_input_nesting_level` e limitar variáveis, partes multipart, cabeçalhos por parte e uploads.
- Se a aplicação não usa multipart/form-data, bloquear esse tipo de requisição no frontend.
- Limite de cgroup/container (`memory.max`) pode substituir o memory_limit com ressalvas. **Não** usar `RLIMIT_AS`/`RLIMIT_DATA`: eles fazem o `mmap()` falhar e disparam justamente o caminho vulnerável.

3.2 CVE-2026-109619 — RCE via estado global obsoleto

CVE-2026-109619	CRÍTICA · CVSS v4.0 9.2
Título oficial	RCE via stale global state
Componente	php-src — núcleo (estado global de erros, sessão, objetos e extensões)
Aviso (GHSA)	GHSA-6wmf-4rv5-p3rp
Vetor CVSS	CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
Fraqueza (CWE)	CWE-416, CWE-755, CWE-824, CWE-1325, CWE-1419
Versões afetadas	< 8.2.35, < 8.3.36, < 8.4.27, < 8.5.12 (e versões sem suporte)
Corrigido em	8.2.35, 8.3.36, 8.4.27, 8.5.12
Créditos	Relatores: sagitzadik-wiz, tomash-areion, lcfr-hax, amyb-oai. Correção: arnaud-lb, iluuu1994, bukka, ndossche

O que esta CVE identifica

Um worker PHP guarda vários estados **globais** (de erro, sessão, objetos, extensões) que, durante uma requisição, apontam para memória que pertence àquela requisição. Esse estado precisa ser zerado antes que a memória seja liberada. A falha: certas operações de entrada, configuração, sessão e tratamento de erro rodam **antes da inicialização normal da requisição seguinte** e acabam lendo o estado deixado pela anterior — que aponta para memória já liberada. Isso é um **use-after-free entre requisições**; com um layout de heap preparado, vira RCE.

O aviso descreve o ataque como a combinação de um **produtor** (operação que publica estado da requisição num local global e não o limpa, geralmente porque um erro fatal — inclusive OOM ou "Maximum execution time exceeded" — a interrompe) e um **consumidor** (operação de uma requisição posterior, no mesmo worker, que usa esse estado antes da inicialização). Até um simples aviso não fatal emitido na fase de limpeza pode repovoar o estado de erro depois que ele foi zerado.

Consumidores confirmados

- **Diagnósticos de INI antes da inicialização:** qualquer warning, notice ou deprecation ao aplicar configurações (ex.: `auto_detect_line_endings=1`, diretivas `mbstring.*`/`iconv.*` legadas, valores inválidos de `memory_limit` ou `date.timezone`, caminhos rejeitados por `open_basedir`). O estado global é acessado antes de o PHP decidir se mostra/loga o aviso — por isso `@`, `error_reporting` ou `display_errors=Off` **não** protegem. No mod_php, isso é alcançável via `.htaccess` e `php_value`; no FPM, quando o frontend envia `PHP_VALUE`/`PHP_ADMIN_VALUE`.
- **Session upload progress:** o recurso de progresso de upload acessa estado de sessão antes da inicialização normal e consome o estado deixado por uma requisição interrompida. Vem ativado por padrão e não exige `session_start()` na aplicação. RCE validada em mod_php e em FPM.

Caso mais forte: backtraces de erro fatal no PHP 8.5

Com `fatal_error_backtraces` ativo (padrão no 8.5), o relatório de erro fatal guarda o backtrace da requisição e esse estado **nunca é zerado** no shutdown. Um diagnóstico na requisição seguinte atinge o valor obsoleto. Foi a base da exploração confirmada contra mod_php.

Impacto

Use-after-free no heap sem autenticação, vazamento de memória e execução remota de código com privilégios do worker. As requisições produtora e consumidora precisam cair no mesmo worker; reciclagem e múltiplos workers reduzem a taxa de sucesso, mas não eliminam o risco.

Mitigações se não for possível atualizar já (parciais)

- PHP 8.5: `fatal_error_backtraces=0` (administrativo) e reiniciar todos os workers — remove o produtor do caso confirmado.
- `session.upload_progress.enabled=0` e reiniciar workers — bloqueia o caminho de sessão. O aviso recomenda manter desativado mesmo após o patch se o recurso não for usado.
- Eliminar erros fatais e avisos alcançáveis pelo atacante (uploads, importações, páginas de erro, destrutores, serialização, handlers de saída, plugins) e diagnósticos de INI aplicados por requisição; preferir configuração de inicialização a overrides por requisição.
- Se desempenho não for crítico, `pm.max_requests=1` limita cada worker a uma requisição.
- Auditoria: ligar `log_errors=On` e `error_reporting=E_ALL` num ambiente isolado e procurar warnings/deprecations repetidos antes dos scripts, erros fatais e timeouts. Ausência de log não prova segurança.

Histórico e divulgação

A PHP Foundation relata que os primeiros sinais do problema de OOM surgiram em 2024, durante a correção de achados da auditoria externa feita pela Quarkslab (financiada pela Sovereign Tech Agency via OSTIF). Na época não havia vetor concreto e a correção travou por meses devido a trade-offs de compatibilidade — a fundação classificou isso como falha estrutural do processo. Em 11/08/2026, a Calif (programa Patch the Planet) e a OpenAI relataram de forma independente uma

RCE com a mesma causa raiz; a Wiz trouxe vetores adicionais em 24/08 e a OpenAI outros em 18/09.

Na véspera do lançamento, além do vazamento dos IDs, a Calif publicou por engano um vídeo do PoC (depois apagado, mas copiado), e a Chainguard publicou imagens com a correção mais de seis horas antes do horário combinado, quebrando o embargo. A equipe não identificou exploits funcionais públicos no momento da divulgação, e o texto de lançamento do PHP não relata exploração ativa.

4. Lançamento de segurança de 24/09/2026

Versões corrigidas: **8.2.34, 8.3.35, 8.4.26 e 8.5.11**. Foram 11 CVEs, a maioria em extensões usadas para fazer requisições de saída (streams HTTP/TLS, SOAP, MySQL) — ou seja, o atacante costuma estar do lado do **servidor remoto** que o PHP consulta, e não do lado do visitante.

4.1 CVE-2026-91765 — SOAP: recursão ilimitada em cleanup_xml_node()

CVE-2026-91765	ALTA · CVSS 7.5
Título oficial	SOAP: Unbounded Recursion in Server-Side cleanup_xml_node
Componente	ext-soap (SoapServer)
Aviso (GHSA)	GHSA-rgrp-mwpx-f6rm
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Fraqueza (CWE)	Não informada no aviso (natureza: consumo descontrolado de pilha)
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	ExPatch-LLC (relator), alexandre-daubois (análise)

O que identifica

Depois que a libxml2 termina o parsing, o SoapServer faz um passo próprio (`cleanup_xml_node()`) que percorre o documento removendo nós em branco e comentários, descendo recursivamente em cada filho **sem contador de profundidade**. Um envelope SOAP com dezenas de milhares de elementos aninhados esgota a pilha. A mesma recursão sem limite existia no decodificador de valores (que segue referências `href`, inclusive em ciclo) e na busca de nós em WSDL.

```
<SOAP-ENV:Body> + '<a>' x 50000 + '</a>' x 50000  ->  SIGSEGV em cleanup_xml_node()
```

Impacto e correção

Uma única requisição HTTP não autenticada derruba o processo; no FPM, uma sequência delas esgota o pool (DoS). O payload é pequeno (comprime para poucos KB). A correção cria `SOAP_MAX_XML_DEPTH` (2048) e `SOAP_MAX_DECODE_DEPTH`, reescreve as travessias de forma iterativa e rejeita cadeias/ciclos de href.

4.2 CVE-2026-91768 — PHP-FPM: bypass de ACL IPv6

CVE-2026-91768	MODERADA · CVSS 6.5
Título oficial	IPv6 ACL bypass in FastCGI listen.allowed_clients due to partial address comparison
Componente	PHP-FPM (main/fastcgi.c)
Aviso (GHSA)	GHSA-62xp-839h-2637
Vetor CVSS	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Fraqueza (CWE)	Não informada
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	I8BL, OSTIF-Derek, iliaal (relatores); iluuu1994; alexandre-daubois

O que identifica

A função `fcgi_is_allowed()` compara endereços IPv6 de clientes usando apenas os **primeiros 12 dos 16 bytes**. Na prática, cada entrada de `listen.allowed_clients` vira uma rede /96 em vez de um endereço exato. No PoC, com `allowed_clients = ::2`, uma conexão vinda de `::1` foi aceita e o script executado.

Impacto e correção

Quem estiver na mesma /96 de um cliente autorizado alcança o endpoint FastCGI — o que costuma significar executar scripts no FPM. Não afeta quem usa socket Unix, só IPv4 ou firewall externo como fronteira real. A correção compara o tamanho completo de `sin6_addr`.

4.3 CVE-2026-91767 — OpenSSL: heap overflow em wildcard de certificado

CVE-2026-91767	MODERADA · CVSS 6.5
Título oficial	Heap-buffer-overflow in php_openssl_matches_wildcard_name on crafted server cert wildcard CN
Componente	ext-openssl (xp_ssl.c)
Aviso (GHSA)	GHSA-xr7j-rvgx-xq5p
Vetor CVSS	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Fraqueza (CWE)	CWE-122 (heap-based buffer overflow)
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	flex0geek

O que identifica

Na verificação de hostname, o tamanho passado a `memchr()` é calculado como `subject_len - suffix_len - prefix_len`. Como a expressão é promovida para `size_t` (sem sinal), um nome curinga cujos caracteres literais somam mais que o hostname faz a subtração “dar a volta” para `SIZE_MAX`. Exemplo: certificado aaa*aa contra o host aaaa → 4 − 2 − 3 = −1 → SIZE_MAX. O `memchr()` varre a memória até achar um ponto ou cair em página não mapeada.

Impacto e correção

Um servidor TLS malicioso (ou confiável pela CA em uso) pode derrubar o cliente PHP durante o handshake — DoS. Os bytes lidos não voltam ao atacante. Afeta qualquer stream cliente com `verify_peer_name` (padrão), como `file_get_contents('https://...')`. A correção usa `size_t` e checa `suffix_len + prefix_len <= subject_len`.

4.4 CVE-2025-14181 — SOAP: integer overflow no parsing HTTP

CVE-2025-14181	MODERADA · CVSS 6.5
Título oficial	Integer overflow to buffer overflow in soap HTTP parsing
Componente	ext-soap (SoapClient, php_http.c)
Aviso (GHSA)	GHSA-cj93-vc83-wgqv
Vetor CVSS	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:L/A:H
Fraqueza (CWE)	Não informada
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	Não listados no aviso

O que identifica

Ao montar respostas com `Transfer-Encoding: chunked`, a função `get_http_body()` testa estouro com `http_buf_size + buf_size + 1 < 0` usando variáveis `int`. Esse teste depende de **overflow de inteiro com sinal**, que em C é comportamento indefinido — o compilador pode simplesmente removê-lo (confirmado com Clang 20 e GCC 15). Sem a checagem, o realloc recebe um tamanho absurdo, aloca pouco e a leitura seguinte escreve além do buffer.

Impacto, correção e contorno

Um servidor SOAP malicioso, ou um MITM em SOAP sem TLS, pode causar desde crash até corrupção de memória no cliente. Exige resposta de vários GB. Correção: tamanho em `size_t`, limite contra ZSTR_MAX_LEN e `zend_string_safe_realloc()`. Contorno: um `memory_limit` baixo gera OOM antes do overflow.

4.5 CVE-2026-17545 — Windows: nomes de dispositivo reservados

CVE-2026-17545	MODERADA · CVSS v4.0 6.9
Título oficial	PHP on Windows: Reserved Device Names Are Not Rejected Before File/Stream I/O which can cause DoS
Componente	php-src — camada de I/O do Windows (win32/ioutil)
Aviso (GHSA)	GHSA-9f67-6fw4-hpfp
Vetor CVSS	CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:H
Fraqueza (CWE)	CWE-67 (tratamento incorreto de nomes de dispositivo do Windows)
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	crisprss

O que identifica

No Windows, nomes como `CON, PRN, AUX, NUL, COM1–9, LPT1–9, CONIN$` e `CONOUT$` são dispositivos, não arquivos — e variações como `NUL.txt` também. As APIs de arquivo/stream do PHP não rejeitavam esses componentes no caminho e os repassavam a `CreateFileW()`. Uma aplicação que monte caminho com entrada do usuário (ex.: `?file=CONIN$` num endpoint de download, ou nome de arquivo de upload) acaba abrindo um dispositivo.

Impacto e correção

`CONIN$` bloqueia esperando entrada do console, prendendo a requisição; repetido em paralelo, esgota os workers (DoS). Só afeta Windows. A correção classifica o caminho e rejeita componentes reservados com `ERROR_INVALID_NAME`, mantendo `NUL` isolado por compatibilidade.

4.6 CVE-2026-91766 — Vazamento de credenciais em redirects HTTP

CVE-2026-91766	MODERADA · CVSS 5.9
Título oficial	Cross-origin credential leak in HTTP stream wrapper redirects
Componente	ext-standard (http_fopen_wrapper.c)
Aviso (GHSA)	GHSA-fpwc-w8rq-cr92
Vetor CVSS	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Fraqueza (CWE)	CWE-200 (exposição de informação), CWE-522 (credenciais mal protegidas)
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	q2a3z, iliaal (relatores); alexandre-daubois (correção)

O que identifica

Ao seguir um redirect, o wrapper `http://` reenviava os cabeçalhos `Authorization`, `Cookie` e `Proxy-Authorization` definidos pelo usuário **sem verificar se o destino mudou** de host, porta ou de HTTPS para HTTP. É a mesma classe de bug corrigida no libcurl em 2018 (CVE-2018-1000007).

```
$ctx = stream_context_create(['http' => [
  'header' => "Authorization: Bearer SECRET",
  'follow_location' => 1]]);
file_get_contents('https://example.com/api', false, $ctx);
// 302 -> https://attacker.example/  => atacante recebe o token
```

Impacto e correção

Quem controla o destino de um redirect recebe o token, o cookie de sessão ou as credenciais de proxy; num downgrade para HTTP, elas trafegam em texto claro. A correção compara a origem (esquema, host, porta) e, se mudar, remove os três cabeçalhos para este e todos os saltos seguintes.

4.7 CVE-2026-92842 — Leitura fora dos limites em filtros convert.*

CVE-2026-92842	MODERADA · CVSS 5.9
Título oficial	OOB read / info leak in convert.* stream filters when line-break-chars contains NUL
Componente	ext-standard (filters.c)
Aviso (GHSA)	GHSA-88hq-2827-7pg6
Vetor CVSS	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Fraqueza (CWE)	CWE-122, CWE-125 (leitura fora dos limites)
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	geeknik

O que identifica

Os filtros `convert.base64-encode` e `convert.quoted-printable-*` aceitam a opção `line-break-chars`. O construtor copia o valor com `pestrdup()`, que para no primeiro byte nulo, mas guarda o tamanho original. Com `"\0X"`, a cópia tem 1 byte e o tamanho registrado é 2; ao emitir a quebra de linha, o filtro copia bytes vizinhos da heap para a saída.

Impacto e correção

Vazamento de memória para quem recebe a saída codificada; quanto maior a opção após o NUL, maior o vazamento. Requer que a aplicação passe bytes do atacante (com NUL) como line-break-chars — raro na prática. Correção: `pestrndup()` com o tamanho real.

4.8 CVE-2026-93682 — Leitura de 1 byte em redirect com Location vazio

CVE-2026-93682	MODERADA · CVSS 5.3
Título oficial	Out-of-bounds read in the HTTP stream wrapper when following a redirect with an empty Location header
Componente	ext-standard (http_fopen_wrapper.c)
Aviso (GHSA)	GHSA-7875-c8px-7q5f
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Fraqueza (CWE)	CWE-125
Versões afetadas	8.1.32+, 8.2.28+, 8.3.18+, 8.4.5+ e todo o 8.5, até < 8.2.34 / 8.3.35 / 8.4.26 / 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	iliaal (relator); jordikroon (correção); devnexen (revisão)

O que identifica

Uma **regressão** introduzida pela correção da CVE-2025-1861: o valor de `Location` passou a ficar num buffer de tamanho exato. Com `Location:` vazio, o buffer tem só o terminador nulo, mas o

código lê o segundo byte para decidir se trata o destino como relativo — um byte além da alocação.

Impacto e correção

O byte nunca é devolvido ao atacante; só decide entre dois destinos de redirect (raiz do host ou diretório atual). Efeito prático: redirect não determinístico e comportamento indefinido. Correção: usar o comprimento armazenado em vez de `strlen()` e proteger a leitura.

4.9 CVE-2026-91769 — TLS: fallback indevido para o Common Name

CVE-2026-91769	MODERADA · CVSS 4.3
Título oficial	TLS Hostname Verification Falls Back to CN After SAN Mismatch
Componente	ext-openssl (xp_ssl.c)
Aviso (GHSA)	GHSA-vvx9-73fr-5jjx
Vetor CVSS	CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Fraqueza (CWE)	Não informada
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	christos-cantina-security, DavidKorczynski, benzdeus

O que identifica

A RFC 6125 manda **ignorar o CN** quando o certificado apresenta identidades de serviço no subjectAltName (SAN). O PHP checava o SAN e, se nada batesse, caía no CN incondicionalmente. Resultado: um certificado com `CN=victim.test` e `SAN=DNS:attacker.test` era aceito para `victim.test`.

Impacto e correção

Permite personificar outro host quando o atacante obtém um certificado (de PKI privada ou CA interna) com o nome-alvo no CN. Afeta `file_get_contents()`, `fopen()` e `stream_socket_client()` sobre https:// e tls://. Agora, se houver SAN DNS/URI/SRV e nenhum casar, a verificação falha; o fallback para CN só vale para certificados sem SAN.

4.10 CVE-2026-6103 — Phar: integer overflow e injeção de entradas TAR

CVE-2026-6103	MODERADA · CVSS 4.0
Título oficial	Phar TAR phar_tar_number() Integer Overflow - Archive Entry Injection
Componente	ext-phar (tar.c)
Aviso (GHSA)	GHSA-j3wh-g957-2m85
Vetor CVSS	CVSS:3.1/AV:L/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Fraqueza (CWE)	Não informada
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	arnoldasr

O que identifica

O campo de tamanho de um cabeçalho TAR tem 11 dígitos octais (até 0x1FFFFFFFF), mas `phar_tar_number()` o acumula num `uint32_t` sem checar estouro. O valor octal `40000000000` vira 0: o parser não pula os dados da entrada e interpreta o **conteúdo do arquivo** como o próximo cabeçalho TAR. O GNU tar rejeita esse arquivo; o `PharData` aceita.

Impacto e correção

Um TAR malicioso mostra ao PHP entradas diferentes das que outras ferramentas veem, e `extractTo()` grava as injetadas — inclusive substituindo arquivos legítimos. O aviso cita o `TarDownloader` do Composer, que usa PharData para pacotes .tar.gz. A correção acumula em 64 bits e rejeita valores inválidos.

4.11 CVE-2025-1218 — mysqlnd: leituras além do pacote

CVE-2025-1218	BAIXA · CVSS 3.1
Título oficial	Various packet overreads in mysqlnd_writeprotocol.c
Componente	ext-mysqlnd (mysqlnd_wireprotocol.c)
Aviso (GHSA)	GHSA-r6x9-5r99-36j7
Vetor CVSS	CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Fraqueza (CWE)	Não informada
Versões afetadas	< 8.2.34, < 8.3.35, < 8.4.26, < 8.5.11
Corrigido em	8.2.34, 8.3.35, 8.4.26, 8.5.11
Créditos	bao00065, TristanInSec

O que identifica e impacto

O parser do protocolo MySQL usa a macro `BAIL_IF_NO_MORE_DATA`, que só garante 1 byte restante, mas várias leituras consomem 2 ou mais bytes antes de checar de novo (pacotes de greeting, OK, EOF, auth-switch, result-set etc.). Inteiros de tamanho variável podem ler até 9 bytes fora. Um servidor MySQL malicioso ou comprometido pode derrubar a aplicação (DoS). Quem só conecta a bancos confiáveis não está exposto. A correção checa o número exato de bytes por leitura.

5. Lançamento de segurança de 30/07/2026

Versões corrigidas: 8.5.9 e 8.4.24 em todos os itens abaixo; 8.3.33 e 8.2.33 onde o ramo é afetado. O lançamento de 27/08/2026 (8.5.10/8.4.25) trouxe apenas correções de bugs, sem CVEs.

5.1 CVE-2026-17543 — Injeção de SQL em ext-pgsql

CVE-2026-17543	ALTA · Alta (score não publicado)
Título oficial	SQL injection in ext-pgsql via E'...' backslash breakout
Componente	ext-pgsql (pg_insert, pg_update, pg_select, pg_delete)
Aviso (GHSA)	GHSA-7qpv-r5mr-78m4
Vetor CVSS	Não publicado no aviso
Fraqueza (CWE)	CWE-89 (SQL injection)
Versões afetadas	< 8.2.33, < 8.3.33, < 8.4.24, < 8.5.9
Corrigido em	8.2.33, 8.3.33, 8.4.24, 8.5.9
Créditos	ExPatch-LLC (relator); alexandre-daubois; iluuu1994; mbeccati

O que identifica

As funções de conveniência `pg_insert()`, `pg_update()`, `pg_select()` e `pg_delete()` escapam valores com `PQescapeStringConn()` e os embrulham numa constante de escape `E'...'`. Com `standard_conforming_strings = on` (padrão desde o PostgreSQL 9.1), essa função **não** escapa a barra invertida — só dobra a aspa. Dentro de `E'...'`, porém, a barra invertida é caractere de escape. Uma barra antes da aspa "come" a primeira aspa duplicada e a segunda fecha a string.

```
pg_select($db, 'user', ['name' => "zzz\\' OR 1=1 --"]);
// SELECT * FROM "user" WHERE "name"=E'zzz\'' OR 1=1 --';
// => retorna todas as linhas
```

Impacto e correção

Injeção de SQL clássica em aplicações que confiam nessas funções para escapar entrada do usuário. A correção passa a usar constantes de string **sem escape** (`'...'`), compatíveis com o que `PQescapeStringConn()` produz. Boa prática independente do patch: usar consultas parametrizadas.

5.2 CVE-2026-17544 — Escrita fora dos limites em bccomp()

CVE-2026-17544	ALTA · Alta (score não publicado)
Título oficial	Out-of-bounds write in bccomp() via crafted operand and scale
Componente	ext-bcmath (libbcmath/src/str2num.c)
Aviso (GHSA)	GHSA-x692-q9x7-8c3f
Vetor CVSS	Não publicado no aviso
Fraqueza (CWE)	CWE-121 (stack overflow), CWE-787 (escrita fora dos limites)
Versões afetadas	< 8.4.24, < 8.5.9 (8.2 e 8.3 não listados como afetados)
Corrigido em	8.4.24, 8.5.9
Créditos	recepasan (relator); iluuu1994 (análise)

O que identifica

Em `bc_str2num()`, quando a escala informada trunca um número e os zeros finais são removidos em seguida, o código reduz `str_scale` (e portanto o buffer alocado), mas **não ajusta o ponteiro** `fractional_end`. A cópia posterior escreve a string original, mais longa, no buffer menor. Como o BCMath usa uma pequena arena na pilha antes da heap, a corrupção pode atingir pilha ou heap.

Impacto e correção

Aplicações que chamam `bccomp()` com operandos e escala controlados pelo usuário (comum em cálculos financeiros) ficam sujeitas a corrupção de memória. O patch adiciona `fractional_end = fractional_new_end;` após o truncamento.

5.3 Outras CVEs de 30/07/2026

- **CVE-2026-7260 (ext-phar, GHSA-vc5h-9ppw-p5f3):** links simbólicos circulares dentro de arquivos phar causam recursão ilimitada, esgotando a pilha C e derrubando o processo (DoS). Afeta 8.2 < 8.2.33, 8.3 < 8.3.33, 8.4 < 8.4.24 e 8.5 < 8.5.9.
- **CVE-2026-9672 (ext-gd):** o ChangeLog registra apenas a atualização da biblioteca libgd embutida para corrigir esta CVE, sem detalhes técnicos publicados no php.net. Relevante para quem processa imagens enviadas por usuários com GD.

6. Recomendações práticas

Prioridade imediata (PHP2Shell)

- Verificar a versão: `php -v` (CLI) e também a do servidor web (`phpinfo()` ou cabeçalho), pois podem diferir.
- Atualizar para 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35, ou para o pacote corrigido da distribuição (Debian, Ubuntu, RHEL, Fedora etc. receberam o patch antecipadamente). Reiniciar **todos** os workers (php-fpm, apache).
- PHP 8.1 ou anterior: não há correção oficial — migrar para um ramo suportado (o 8.2 recebe correções de segurança só até 31/12/2026) ou usar um fornecedor LTS.
- Em painéis gerenciados (ex.: Laravel Forge), confirmar que a atualização automática cobre o PHP — no caso da Forge, ela não cobre.
- Enquanto não atualiza: `session.upload_progress.enabled=0`, `fatal_error_backtraces=0` (8.5), limites de multipart no frontend; considerar tirar do ar o que não puder ser corrigido.

Detecção e monitoramento (Blue Team)

- Alertar sobre crashes/segfaults de workers PHP (logs do Apache/FPM: *child exited on signal 11*) e picos de “Allowed memory size exhausted”.
- No WAF/proxy, observar requisições multipart anômalas: muitos cabeçalhos por parte, muitos campos de arquivo vazios, nomes de campo profundamente aninhados, corpo sem Content-Length.
- Observar processos filhos inesperados do usuário do servidor web (www-data/apache) — típico pós-RCE (web shells, crontabs).
- Procurar warnings/deprecations de INI repetidos antes da execução dos scripts (sinal do caminho de CVE-2026-109619).

Boas práticas para as demais CVEs

- Requisições de saída: não confiar em `follow_location` com cabeçalhos de autenticação; preferir cURL com opções explícitas e TLS sempre.
- Banco de dados: preferir consultas preparadas (PDO/pg_query_params) às funções de conveniência `pg_*()`.
- Arquivos: nunca montar caminhos com entrada do usuário sem lista de permissão; no Windows, isso inclui nomes de dispositivo.
- Arquivos compactados de terceiros (TAR/phar): validar com ferramentas externas e extrair em diretório isolado.
- Endpoints SOAP públicos: limitar tamanho de corpo e profundidade XML no proxy.

Apêndice A — CVEs do PHP no 1º semestre de 2026 (resumo)

Tabela de referência com as CVEs listadas no ChangeLog oficial do PHP 8.5 entre dezembro de 2025 e julho de 2026. Descrições resumidas a partir das entradas do ChangeLog.

CVE	Componente	Descrição resumida	Corrigida em (8.5)
CVE-2026-14355	ext-openssl	Corrupção de memória em openssl_encrypt() com AES-WRAP-PAD	8.5.8 (02/07)
CVE-2026-44927	ext-uri (uriparser)	Truncamento de diferença de ponteiros para int	8.5.7 (04/06)
CVE-2026-44928	ext-uri (uriparser)	EqualsUri pode considerar iguais URIs diferentes	8.5.7 (04/06)
CVE-2026-7263	ext-dom	C14N() emite declarações xmlns duplicadas após setAttributeNS()	8.5.6 (07/05)
CVE-2026-6735	PHP-FPM	XSS no endpoint de status	8.5.6 (07/05)
CVE-2026-7259	ext-mbstring	Desreferência de ponteiro nulo via mb_ereg_search_init()	8.5.6 (07/05)
CVE-2026-6104	ext-mbstring	Acesso fora dos limites em mbfl_name2encoding_ex()	8.5.6 (07/05)
CVE-2025-14179	PDO_Firebird	Injeção de SQL via bytes NUL em strings citadas	8.5.6 (07/05)
CVE-2026-6722	ext-soap	Ponteiro ref_map obsoleto com Apache Map	8.5.6 (07/05)
CVE-2026-7261	ext-soap	Use-after-free após falha de parsing de cabeçalho (SOAP_PERSISTENCE_SESSION)	8.5.6 (07/05)
CVE-2026-7262	ext-soap	Checagem de NULL quebrada em valor de Apache map	8.5.6 (07/05)
CVE-2026-7568	ext-standard	Overflow de inteiro com sinal em offset de array de char	8.5.6 (07/05)
CVE-2026-7258	ext-standard	Passagem inconsistente de char para funções ctype.h	8.5.6 (07/05)
CVE-2026-12184	Streams	Segfault em file_get_contents() com URL https e proxy	8.5.6 (07/05)
CVE-2026-42371	ext-uri (uriparser)	Truncamento numérico em comparação de intervalo de texto	8.5.6 (07/05)
CVE-2025-14180	PDO	Desreferência nula no resultado de quoting	8.5.1 (18/12/2025)
CVE-2025-14178	ext-standard	Heap buffer overflow em array_merge()	8.5.1 (18/12/2025)
CVE-2025-14177	ext-standard	Vazamento de memória (informação) em getimagesize()	8.5.1 (18/12/2025)
CVE-2025-67899	ext-uri (uriparser)	Recursão ilimitada e consumo de pilha	8.5.1 (18/12/2025)

Fontes de pesquisa

Todas as fontes foram consultadas em 21/10/2026. Os avisos GHSA do repositório php/php-src são a fonte primária de cada CVE.

Avisos oficiais (GitHub Security Advisories — php/php-src)

[1] GHSA-w8hw-w9fx-j79w — RCE via OOM corruption (CVE-2026-109618)
https://github.com/php/php-src/security/advisories/GHSA-w8hw-w9fx-j79w

[2] GHSA-6wmf-4rv5-p3rp — RCE via stale global state (CVE-2026-109619)
https://github.com/php/php-src/security/advisories/GHSA-6wmf-4rv5-p3rp

[3] GHSA-rgrp-mwpx-f6rm — SOAP unbounded recursion (CVE-2026-91765)
https://github.com/php/php-src/security/advisories/GHSA-rgrp-mwpx-f6rm

[4] GHSA-62xp-839h-2637 — FPM IPv6 ACL bypass (CVE-2026-91768)
https://github.com/php/php-src/security/advisories/GHSA-62xp-839h-2637

[5] GHSA-xr7j-rvgx-xq5p — OpenSSL wildcard overflow (CVE-2026-91767)
https://github.com/php/php-src/security/advisories/GHSA-xr7j-rvgx-xq5p

[6] GHSA-cj93-vc83-wgqv — SOAP HTTP integer overflow (CVE-2025-14181)
https://github.com/php/php-src/security/advisories/GHSA-cj93-vc83-wgqv

[7] GHSA-9f67-6fw4-hpfp — Windows reserved device names (CVE-2026-17545)
https://github.com/php/php-src/security/advisories/GHSA-9f67-6fw4-hpfp

[8] GHSA-fpwc-w8rq-cr92 — Credential leak in redirects (CVE-2026-91766)
https://github.com/php/php-src/security/advisories/GHSA-fpwc-w8rq-cr92

[9] GHSA-88hq-2827-7pg6 — convert.* filters OOB read (CVE-2026-92842)
https://github.com/php/php-src/security/advisories/GHSA-88hq-2827-7pg6

[10] GHSA-7875-c8px-7q5f — Empty Location OOB read (CVE-2026-93682)
https://github.com/php/php-src/security/advisories/GHSA-7875-c8px-7q5f

[11] GHSA-vvx9-73fr-5jjx — TLS CN fallback (CVE-2026-91769)
https://github.com/php/php-src/security/advisories/GHSA-vvx9-73fr-5jjx

[12] GHSA-j3wh-g957-2m85 — Phar TAR overflow (CVE-2026-6103)
https://github.com/php/php-src/security/advisories/GHSA-j3wh-g957-2m85

[13] GHSA-r6x9-5r99-36j7 — mysqlnd overreads (CVE-2025-1218)
https://github.com/php/php-src/security/advisories/GHSA-r6x9-5r99-36j7

[14] GHSA-7qpv-r5mr-78m4 — pgsql SQL injection (CVE-2026-17543)
https://github.com/php/php-src/security/advisories/GHSA-7qpv-r5mr-78m4

[15] GHSA-x692-q9x7-8c3f — bccomp() OOB write (CVE-2026-17544)
https://github.com/php/php-src/security/advisories/GHSA-x692-q9x7-8c3f

[16] Política de segurança do php-src
https://github.com/php/php-src/security

Projeto PHP e PHP Foundation

[17] PHP 8 ChangeLog (php.net)
https://www.php.net/ChangeLog-8.php

[18] PHP Foundation — Today's PHP Security Release, and How We're Strengthening PHP Security
https://thephp.foundation/blog/2026/10/21/todays-php-security-release-and-how-were-strengthening-php-security/

Rastreadores de vulnerabilidade

[19] CIRCL Vulnerability Lookup — CVE-2026-7260 (inclui dados do NVD)
https://cve.circl.lu/cve/CVE-2026-7260

[20] Debian Security Tracker — CVE-2026-7260
https://security-tracker.debian.org/tracker/CVE-2026-7260

[21] Debian Security Tracker — CVE-2026-93682
https://security-tracker.debian.org/tracker/CVE-2026-93682

[22] Debian Security Tracker — CVE-2026-92842
https://security-tracker.debian.org/tracker/CVE-2026-92842

[23] Debian Security Tracker — CVE-2026-6735
https://security-tracker.debian.org/tracker/CVE-2026-6735

Cobertura de imprensa e fornecedores

[24] Help Net Security — PHP2Shell: Critical PHP vulnerabilities patched
https://www.helpnetsecurity.com/2026/10/21/php2shell-php-vulnerabilities-patched-cve-2026-109618-cve-2026-109619/

[25] Qualys Threat Research — PHP announces critical security release
https://blog.qualys.com/vulnerabilities-threat-research/2026/10/20/php-announces-critical-security-release-for-two-vulnerabilities

[26] Laravel Forge — PHP security advisory
https://laravel.com/forge/docs/knowledge-base/php-security-release-october-2026

[27] Brandefense — PHP2Shell: PHP RCE CVE-2026-109618, 109619
https://brandefense.io/blog/php2shell-php-rce-cve-2026-109618-109619/

[28] InMotion Hosting — Critical PHP Security Release October 21, 2026
https://www.inmotionhosting.com/support/news/php-critical-security-release-october-2026/

[29] GoDaddy — Important PHP security update
https://www.godaddy.com/resources/news/important-php-security-update-what-website-owners-need-to-do

[30] Codeable — PHP Security Release on 21 October 2026
https://www.codeable.io/blog/php-vulnerability-cve-2026-109618/